

LVChat

Full Monty Audit Report

3 CRITICAL · 10 HIGH · 6 MEDIUM · 0 LOW

Generated: August 18, 2026 at 08:55 PM
Scope: FULL_MONTY
Total findings: 19 · Security: 2 · Performance: 8 · UI/UX: 9

Executive Summary

Metric	Value
Total Findings	19
Critical Severity	3
High Severity	10
Medium Severity	6
Low Severity	0
---	---
Security findings	2
Performance findings	8
UI/UX findings	9
---	---
GPT-OSS-20b findings	0
MiniMax/grep findings	19

Methodology

Security scan (Step 2.5): Two-model parallel approach. Model A — GPT-OSS-20b at 192.168.8.147:1234 (Botbox2): static per-file security review using a 6-thread worker pattern. Model B — MiniMax + local grep sweep: regex/heuristic pass over all source files. Vulnerability classes scanned: SQLi, XSS, CSRF, IDOR,

AuthBypass, HardcodedSecret, SessionHardening, FileUpload/PathTraversal, TimingAttack, Cron/TOCTOU, InfoDisclosure, InsecureDeserialization, OpenRedirect, MissingRateLimit, CORS/OriginCheck, HeaderInjection.

Performance scan (Step 2.6): Same two-model pattern. Classes scanned: N+1, MissingIndex, UnboundedResultSet, SyncExternalCall, MissingCache, AssetBloat, RenderBlocking, ExcessiveDOM, MemoryHotPath, ResourceLeaks, CronInefficiency, ColdStart, FrontendRuntime, NetworkPayload, ConnectionPool, Concurrency.

UI/UX scan (Step 2.7): Same two-model pattern plus Playwright screenshot review where available. Classes scanned: a11y, FormUX, LoadingStates, ErrorUX, InformationArchitecture, VisualConsistency, ResponsiveDesign, i18n, StateFeedback, Discoverability, NativeDialog, DataBinding, DeadUI, ColorContrast, Microcopy, Motion, PrintExport.

Severity scale: Critical (direct exploit / unusability) → High (realistic exploit / visible breakage) → Medium (preconditions / tolerable lag) → Low (defense-in-depth / polish).

Scope rule (CRITICAL): *install/*, *e2e/*, and *tests/* directories are excluded from live-code audit scope. They are development-only and must never reach production. These folders should be manually deleted before any upload.

Security Findings

2 finding(s): 0 Critical · 0 High · 2 Medium · 0 Low

H-01	MEDIUM	Missing Security Header	MiniMax (grep sweep)
File : Line	src/bootstrap.php : 197		
Vulnerable Code	// HSTS only — no CSP, no X-Content-Type-Options, no Referrer-Policy		
Description	Application lacked Content-Security-Policy, X-Content-Type-Options, and Referrer-Policy headers.		
Remediation	Added CSP (default-src 'self' + controlled exceptions), X-Content-Type-Options: nosniff, Referrer-Policy: strict-origin-when-cross-origin		

H-02	MEDIUM	LIKE Wildcard Injection	MiniMax (grep sweep)
File : Line	src/controllers/AdminController.php : 118		
Vulnerable Code	\$params = ["%\$term%", "%\$term%"];		
Description	User search term used in LIKE clause without escaping % and _ metacharacters.		
Remediation	Wrapped \$term with addcslashes(\$term, '%_\\') before LIKE parameterization.		

Performance Findings

8 finding(s): 2 Critical · 3 High · 3 Medium · 0 Low

P-01	HIGH	Missing Index	MiniMax (grep sweep)
File : Line	schema.sql : 4		
Vulnerable Code	CREATE TABLE users (...last_ip TEXT, last_seen TEXT...)		
Description	users.last_ip and users.last_seen had no indexes. IP ban lookups and online-user queries performed full table scans.		
Remediation	Added idx_users_last_seen and idx_users_last_ip indexes in schema v41 migration.		

P-02	HIGH	Missing Index	MiniMax (grep sweep)
File : Line	schema.sql : 250		
Vulnerable Code	CREATE TABLE chat_logs (...)		
Description	chat_logs.channel_name had no index. Admin log export and event log queries scanned the entire append-only table.		
Remediation	Added idx_chat_logs_channel (channel_name, created_at) composite index in schema v41 migration.		

P-03	MEDIUM	Missing Caching	MiniMax (grep sweep)
File : Line	src/services/UrlBanService.php : 73		
Vulnerable Code	Database::all('SELECT * FROM banned_urls')		
Description	Full banned_urls table loaded on every embed fetch and channel URL validation with no caching.		
Remediation	Added per-request static cache (\$cachedBans) invalidated on add()/remove() admin operations.		

P-04	CRITICAL	N+1 Query	MiniMax (grep sweep)
File : Line	src/services/MessageService.php : 89		
Vulnerable Code	COALESCE((SELECT u.username FROM users u WHERE u.id = m.sender_id), ...)		
Description	msgSelect() used 8 correlated subqueries per message row. For a 60-message history, this was 480+ subqueries per page load.		
Remediation	Replaced all correlated subqueries with LEFT JOINS (users, guests, channels, reply-to messages). Reduced to ~6 JOINS total.		

P-05	CRITICAL	Full Table Scan	MiniMax (grep sweep)
File : Line	src/services/commands/OperCommands.php : 178		
Vulnerable Code	SELECT * FROM users WHERE last_ip IS NOT NULL		
Description	IP-based ban/kick loaded every registered user into memory to check IP matches. On 100k users this was catastrophic.		
Remediation	Changed SELECT * to SELECT id, username, last_ip (only needed columns). Index on last_ip added in schema v41.		

P-06	HIGH	Unbounded Result Set	MiniMax (grep sweep)
File : Line	src/services/EventLogService.php : 134		
Vulnerable Code	SELECT * FROM chat_logs WHERE channel_name = ? ORDER BY id ASC		
Description	Fetched ALL log rows for a channel with no LIMIT. Active channels could produce millions of rows.		
Remediation	Added time-range filtering (started_at/ended_at from event) and LIMIT 50000.		

P-07	MEDIUM	N+1 Query	MiniMax (grep sweep)
File : Line	src/services/PushService.php : 371		
Vulnerable Code	Database::all('SELECT * FROM push_subscriptions WHERE user_id = ?', ...)		
Description	Push subscriptions fetched per-notify with SELECT * from full table. Same user's subscriptions fetched 3-4 times per request.		
Remediation	Added per-request static cache (subsForUser) with SELECT of only needed columns (endpoint, p256dh, auth).		

P-08	MEDIUM	Render Blocking	MiniMax (grep sweep)
File : Line	views/chat/app.php : 1374		
Vulnerable Code	<script src="marked.min.js"></script>		
Description	Script tags loaded without defer, blocking DOMContentLoaded and each other.		
Remediation	Added defer attribute to all 5 script tags (marked, purify, highlight, icons, app).		

UI/UX Findings

9 finding(s): 1 Critical · 7 High · 1 Medium · 0 Low

U-01	CRITICAL	Accessibility	MiniMax (grep sweep)
File : Line	views/layout.php : 52		
Vulnerable Code			
Description	Site logo had empty alt="" on every page. Screen readers announced nothing.		
Remediation	Changed to alt="<?= h(config_get('site_name', 'LVChat')) ?>" across layout.php and all 6 auth views.		

U-02	HIGH	Accessibility	MiniMax (grep sweep)
File : Line	views/chat/app.php : 711		
Vulnerable Code	<textarea id="chat-input" name="content" ...>		
Description	Chat textarea had no aria-label or associated label element.		
Remediation	Added aria-label="Message input" to the textarea element.		

U-03	HIGH	Accessibility	MiniMax (grep sweep)
File : Line	views/chat/join.php : 31		
Vulnerable Code	<input class="input" type="password" name="key">		
Description	Channel key input had no <label> element.		
Remediation	Added <label class="label" for="join-key">Channel key</label> above the input.		

U-04	HIGH	Accessibility	MiniMax (grep sweep)
File : Line	views/browse/index.php : 99		
Vulnerable Code	<input id="ch-search" ... placeholder="Search...">		
Description	Channel browser search and filter controls had no aria-label attributes.		
Remediation	Added aria-label="Search channels" and aria-label="Filter channels".		

U-05	HIGH	Motion	MiniMax (grep sweep)
File : Line	src/assets/input.css : 379		
Vulnerable Code	@keyframes msg-in { ... }		
Description	Five @keyframes animations ran without respecting prefers-reduced-motion. WCAG 2.3.3 violation.		
Remediation	Added @media (prefers-reduced-motion: reduce) block disabling all animations and transitions.		

U-06	HIGH	Print	MiniMax (grep sweep)
File : Line	src/assets/input.css : 304		
Vulnerable Code	body.chat-app { position: fixed; ... }		
Description	No @media print styles. Chat app's fixed positioning caused blank pages when printing.		
Remediation	Added @media print rules: hide chrome, set body to static, ensure message list visible.		

U-07	HIGH	Tap Targets	MiniMax (grep sweep)
File : Line	public/assets/js/app.js : 336		
Vulnerable Code	px-2 py-0.5 rounded-md		
Description	Reaction buttons (20px tall) and message action buttons (24px) were below WCAG 44px minimum tap target.		
Remediation	Increased to px-2.5 py-1 for reactions and p-2.5 for action buttons.		

U-08	HIGH	Accessibility	MiniMax (grep sweep)
File : Line	views/chat/app.php : 919		
Vulnerable Code	<div id="browse-modal" class="...">		
Description	Modal dialogs lacked role="dialog", aria-modal, and aria-labelledby attributes.		
Remediation	Added role="dialog" aria-modal="true" aria-labelledby to browse, join, create-channel, report, and chan-settings modals with m		

U-09	MEDIUM	Form UX	MiniMax (grep sweep)
File : Line	views/chat/app.php : 723		
Vulnerable Code	Type / for commands · @nick to mention · ...		
Description	Hint bar was missing :emoji: and ~~strikethrough~~ shortcut documentation.		
Remediation	Added :emoji: and ~~strikethrough~~ to the hint bar text.		